

Quién puede entrar, y quién decide

El sistema de permisos completo: las cuatro identidades que existen, qué puede hacer cada una, cómo se da y se quita acceso, y por qué está diseñado así para cumplir con el RGPD.

Verificado sobre `main`. Decisiones en `Decisiones.md`; evidencia de pruebas en `Registro-QA.md`.

La regla que ordena todo lo demás

Noesis distingue dos cosas que casi todos los programas mezclan:
administrar una cuenta y **ver lo que hay dentro**.

Tú, como propietario de la plataforma, puedes hacer lo primero de forma completa: dar acceso, quitarlo, cambiar el plan, cortar a un tercero. **No puedes hacer lo segundo**. No es una limitación técnica pendiente de resolver: es la decisión que hace defendible el producto ante un cliente que te confía las facturas de su negocio.

1. Las cuatro identidades

Cada una entra por una puerta distinta y tiene un alcance distinto. Confundirlas es el origen de casi todos los errores de permisos.

IDENTIDAD	QUIÉN ES	ENTRA POR	ALCANCE
Administración	Tú y tu socio	/admin , con Google obligatorio en producción	Todas las cuentas, solo para administrarlas
Titular	El autónomo dueño del negocio	/login , contraseña o Google	Todo lo suyo, y solo lo suyo
Trabajador	Su equipo de campo	WhatsApp, con código de un solo uso	Su parte del día, sin ver dinero
Gestoría	Su asesor fiscal	/gestoria/login , con segundo factor	Solo los negocios que le hayan dado acceso

El aislamiento entre negocios tiene un solo guardián: la función `auth_guard` . Cada petición a `/b/...` o `/api/...` compara el negocio del usuario con el de la URL y corta si no coinciden. Que sea un único punto es deliberado: una regla repartida por cincuenta sitios se rompe en el sitio cincuenta y uno.

2. Qué puede hacer cada uno

La tabla que resuelve las discusiones. Lo importante son las casillas en rojo.

	ADMINISTRACIÓN	TITULAR	TRABAJADOR	GESTORÍA
Activar o desactivar una cuenta	Sí	No	No	No
Cambiar el plan de una cuenta	Sí	Vía Stripe	No	No
Suspender el acceso de una persona	Sí	Todavía no	No	No
Ver por qué falló una entrega	Sí	Sí	No	No
Ver clientes, facturas y documentos	No	Sí	No	Los suyos
Modificar datos del negocio	No	Sí	No	No
Entrar en el panel de un cliente	No	Sí	No	No
Emitir o enviar una factura	No	Sí	No	No
Aportar un coste de obra	No	Sí	Si se le permite	No
Descargar todos sus datos (RGPD)	No	Sí	No	No
Borrar la cuenta entera (RGPD)	No	Sí	No	No

Las cuatro filas en negrita son la frontera de privacidad. **Administración no las cruza**, y por eso el producto puede prometer aislamiento sin letra pequeña.

3. Qué desbloquea cada plan

El plan no es solo un precio: es el permiso. Cambiarlo cambia lo que la cuenta puede usar, en el servidor y no solo ocultando botones.

FUNCIÓN	AUTÓNOMO	NEGOCIO	PREMIUM
Agenda, clientes, facturas y cobros	Sí	Sí	Sí
Proyectos, costes y rentabilidad	No	Sí	Sí
Equipo y registro de jornada	No	Sí	Sí
Gestoría conectada	No	Sí	Sí
Análisis financiero avanzado	No	Sí	Sí

Durante la prueba gratuita, la cuenta tiene permisos de Premium. Es intencionado: el autónomo debe poder ver todo antes de elegir. Al vencer, no pierde funciones: pasa a **modo consulta**, donde sigue viendo su negocio entero pero no puede crear, cambiar ni enviar. Sus datos nunca se tocan.

4. Cómo se da y se quita acceso

Todo ocurre en la ficha de la cuenta, en `/admin/cuentas/<id>`. Cuatro operaciones.

01

Activar una cuenta **SIN PASAR POR STRIPE**

Sección *Permisos de la cuenta* → elige plan → **Activar cuenta**. La cuenta sale de modo consulta al instante y desbloquea las funciones del plan elegido.

Esto no cobra. Es un alta manual, útil para un piloto o para desbloquear a alguien mientras se resuelve un pago. La facturación real sigue siendo cosa de Stripe.

02

Retirar el acceso de una cuenta **REVERSIBLE**

Pasar a modo consulta. El titular sigue entrando y viendo todo lo suyo, pero no puede crear, enviar ni ejecutar automatizaciones. No se borra nada.

Es la palanca correcta para un impago: castiga el uso, no la propiedad de los datos.

03

Suspender a una persona concreta **EFFECTO INMEDIATO**

Sección *Quién puede entrar* → **Suspender acceso**, con el motivo escrito.

Es la palanca proporcionada: un empleado que se va no debería obligar a apagar la cuenta de toda la empresa. Sus sesiones abiertas **se cierran en la petición siguiente**, no cuando caduque una cookie, y tampoco puede volver a entrar aunque su contraseña siga siendo correcta.

Hay tres cosas que el sistema **no** te dejará hacer, porque dejarían una cuenta inaccesible: suspenderte a ti mismo, suspender al titular de un negocio, y suspender a la última persona con acceso. Cada una está cubierta por una prueba automática.

Cortar el acceso de una gestoría MEDIDA DE SEGURIDAD

La misma sección lista las gestorías con acceso a esos datos y permite revocarlas.

La vía normal es que lo haga el titular desde su panel: la relación con su asesor es suya, no tuya. Esto existe para lo que no puede esperar —una credencial profesional comprometida— y por eso queda registrado como aviso de seguridad.

5. Cómo cumple con el RGPD

Cuatro principios del reglamento y cómo los resuelve el diseño. Esto es lo que hay que poder explicar si un cliente o un inspector lo pregunta.

Minimización ART. 5.1.C

Administración ve **recuentos y estados**: cuántos clientes, cuántas facturas, qué cola está atascada y con qué error del proveedor. Nunca nombres, conceptos, importes ni documentos.

Por qué así: para dar soporte no hace falta leer la factura, hace falta saber por qué no salió. El diagnóstico se diseñó para responder eso con el mínimo dato posible, y una prueba automática falla si alguien cuela el destinatario o el asunto.

Papeles claros ART. 28

El autónomo es el **responsable** de los datos de sus clientes. Noesis es el **encargado**: los trata por cuenta de él y con sus instrucciones.

Por qué importa: por eso administración no entra en las cuentas. Un encargado que puede leer los datos a voluntad, sin instrucción ni registro, deja de parecer un encargado. Mantener esa puerta cerrada es lo que hace que el contrato que firmáis con cada cliente describa la realidad.

Trazabilidad ART. 30 Y 32

Cada acción administrativa —activar, desactivar, suspender a alguien, revocar a una gestoría— se escribe en una bitácora **encadenada por hash**: cada entrada firma la anterior, así que no se puede alterar el pasado sin que se note.

Por qué así: un registro que se puede editar no prueba nada. El encadenado convierte la bitácora en evidencia utilizable ante una reclamación.

Derechos de la persona ART. 15 A 20

El titular descarga **todos** sus datos en JSON cuando quiera, exporta los de un cliente final concreto —cuando ese cliente ejerce su derecho ante él— y puede borrar su cuenta entera escribiendo BORRAR.

Por qué lo ejerce él y no tú: los derechos se ejercen ante el responsable. Si administración pudiera exportar o borrar los datos de un cliente, estaría actuando como responsable de datos que no le pertenecen.

Lo que falta por hacer, y es vuestro

El código respeta estos principios, pero el papel tiene que decir lo mismo. Antes del piloto hay que revisar con un profesional que el **contrato de encargo de tratamiento** describa exactamente lo que hace el sistema: que administración gestiona el acceso pero no lee el contenido, que la bitácora es encadenada, y qué subencargados intervienen (Railway, Meta, Stripe, el proveedor de correo y el de IA).

Está anotado como P0 en `Tareas-vivas.md`. Una revisión propia no sustituye la de un abogado.

6. Situaciones reales

Qué hacer en los seis casos que van a pasar de verdad.

SITUACIÓN	QUÉ HACES
Un piloto empieza y quieres darle acceso sin cobrarle	Ficha de la cuenta → Activar con el plan Negocio. Recuerda que no cobra.
Un cliente deja de pagar	Pasar a modo consulta. Conserva sus datos y los sigue viendo; recupera todo al reactivar.
Un empleado de tu cliente se va de la empresa	Suspender solo a esa persona, con el motivo. El resto del equipo no se entera.
Se ha despedido y sospechas que entró anoche	Suspender corta sus sesiones al instante. Después, la bitácora dice qué se hizo y cuándo.
La gestoría de un cliente ha tenido una brecha	Revocar su acceso desde la ficha, y avisar al titular: la relación es suya y debe decidir si la restablece.
Un cliente te pide que borres todo lo suyo	No lo haces tú: le explicas dónde está el botón en su panel. Es su derecho y su decisión, y así queda constancia de que fue él.

7. Cómo sabemos que funciona

Cada barrera de esta guía tiene una prueba automática, y cada prueba se verificó desactivando lo que protege.

LO QUE SE GARANTIZA	CÓMO SE COMPROBÓ
Una sesión abierta muere al suspender	Se desactivó el corte y la prueba falló
Un suspendido no vuelve a entrar	Se desactivó la comprobación del login y la prueba falló
No se puede dejar una cuenta sin acceso	Se desactivaron las tres protecciones y la prueba falló
El diagnóstico no filtra datos del cliente	Se coló el destinatario a propósito y la prueba falló
Nadie pierde acceso al actualizar la base	Usuario creado antes de migrar, comprobado después
Las cuentas siguen aisladas entre sí	185 pruebas de administración, seguridad, sesión y aislamiento

Una prueba que pasa siempre no protege de nada. Por eso cada una se rompió a propósito antes de darla por buena: si al quitar la protección la prueba sigue verde, es que no estaba probando lo que decía.

Verificado sobre `main`: `web/deps.py` (`auth_guard`), `web/auth.py`, `web/routers/account.py`, `web/routers/admin.py`, `db.py` (`set_user_access`, `subscription_allows_access`, `admin_support_delivery_failures`, RGPD) y `adapters/billing.py`.

Los permisos por plan y el estado del piloto cambian: la fuente viva es `project-state.json`.